

CRA COMPLIANCE CHECKLIST

MODULE A

COMPLIANT

Software Manufacturer's Self-Assessment for EU Cyber Resilience Act

This checklist provides guidance and self-assessment verification criteria aligned with the **Eclipse Foundation's Open Regulatory Compliance (ORC) Working Group**—alongside its affiliated open-source compliance initiatives (such as the **OCCTET Project** and the **sCC4CRA / Simplified Common Criteria** framework) to assist software manufacturers and open-source stewards in achieving compliance with the EU Cyber Resilience Act (CRA).

***Executive Brief:** Under the CRA, products with digital elements classified as "Default / Standard" (as well as certain qualifying open-source software under Article 32) can demonstrate compliance via Conformity Assessment Module A (Internal Production Control / Manufacturer Self-Assessment).*

1. SCOPE, PRODUCT CLASSIFICATION & SUPPORT PERIOD

This preliminary section ensures the product is accurately categorized and its operational boundaries are formally defined:

- ☐ **Scope Verification:** Confirm whether the software qualifies as a Product with Digital Elements (PDE) having direct or indirect logical or network data connections.
- ☐ **Risk Tiering:** Establish if the product falls under Default/Standard (eligible for pure self-assessment), Important (Class I / Class II), or Critical.
- ☐ **Defined Support Period:** Formally document the guaranteed lifetime during which the manufacturer will provide free security updates (minimum expected lifetime).

2. PRODUCT SECURITY BY DESIGN & DEFAULT (ANNEX I, PART I)

Assess whether cybersecurity controls are built into the product's architecture from conception to delivery:

Requirement Area	Checklist Verification Items
No Known Exploitable Flaws	Provide documented evidence that the software is shipped free of known, exploitable vulnerabilities.
Secure by Default	Verify that default settings are hardened; attack surfaces, unnecessary services, and ports are minimized; and factory reset or configuration reset mechanisms are available.
Access Control & Identity	Enforce robust authentication, authorization, token encryption, and least-privilege access across all logical interfaces.
Data Protection	Enforce encryption of sensitive data in transit and at rest, and implement protection against unauthorized data modification or corruption.
Data Minimization	Verify that the software only processes and retains data strictly necessary for its intended functionality.

Requirement Area	Checklist Verification Items
Resilience & Availability	Verify protection against denial-of-service (DoS) conditions and mitigation of negative impacts on other network devices.

3. VULNERABILITY HANDLING & SUPPLY CHAIN OBLIGATIONS (ANNEX I, PART II)

Evaluate the operational workflows established for ongoing dependency management and lifecycle security:

- ☐ **Software Bill of Materials (SBOM):** Maintain a complete, machine-readable inventory of all first- and third-party dependencies utilizing standards like CycloneDX or SPDX.
- ☐ **Supply Chain Due Diligence:** Document a formal process to screen, test, and vet third-party and open-source components for inherited flaws prior to integration.
- ☐ **Security Testing in CI/CD:** Execute ongoing vulnerability scanning, static/dynamic analysis (SAST/DAST), code reviews, and regular penetration testing.
- ☐ **Coordinated Vulnerability Disclosure (CVD):** Publish a clear vulnerability reporting policy (e.g., SECURITY.md or a dedicated security contact point) defining how external researchers can privately report flaws.
- ☐ **Patch Management:** Establish capabilities to rapidly develop, validate, and securely distribute security fixes and patches (keeping security patches distinct from functional updates).

4. INCIDENT & VULNERABILITY REPORTING READINESS (ARTICLE 14)

Establish and verify incident response workflows against mandatory regulatory notification windows:

- ☐ **24-Hour Early Warning:** Implement documented escalation procedures to notify the designated CSIRT and ENISA within 24 hours of becoming aware of any actively exploited vulnerability or severe security incident.
- ☐ **72-Hour Notification:** Submit a detailed follow-up notification report containing initial impact analysis and mitigation/workaround steps.
- ☐ **Final Report:** Deliver a concluding report containing comprehensive analysis and corrective updates within 14 days after a patch is available (or 1 month for severe unresolved incidents).

5. TECHNICAL DOCUMENTATION & CONFORMITY (ANNEX VII & MODULE A)

Compile the formal technical documentation files required to support conformity and affix the CE mark:

- ☐ **Cybersecurity Risk Assessment:** Document a formal threat model and risk assessment identifying potential threats across design, deployment, and maintenance phases.
- ☐ **User Information & Manuals (Annex II):** Provide clear end-user documentation detailing secure installation, recommended security configuration, and decommission or end-of-life procedures.
- ☐ **EU Declaration of Conformity (DoC):** Draft and sign a formal legal declaration confirming compliance with all applicable essential requirements of the CRA.
- ☐ **CE Marking:** Affix the CE mark legibly to the software packaging, documentation, or digital interface in accordance with regulatory rules.